

Release Recommendation

WebMind — RAG-Powered Website Chatbot | <https://claysys-rag-project.vercel.app/> | Assumed deployment date: tomorrow

RECOMMENDATION: NOT READY FOR RELEASE

Two Critical-severity defects allow one user to see another user's private chats and knowledge bases. This must be fixed and re-verified before production deployment.

1. Testing Summary

This recommendation is based on the full testing effort completed for this assignment: manual functional testing, exploratory testing, and a dedicated AI-testing suite.

Activity	Deliverable	Result
Manual functional testing	TestCases.xlsx (Part 3)	82 test cases — 71 PASS, 10 FAIL, 1 Not Executed (~87%)
Exploratory testing	DefectReport.xlsx (Part 4)	09 defects logged — 2 Critical, 2 High, 2 Medium, 3 Low
AI-specific testing	AITestingSuite (Part 9)	50 test cases — 19 PASS, 1 FAIL (existing), 30 new cases
API testing	Postman Collection (Part 10)	24 requests covering auth, knowledge base, and end points

2. Critical Blocking Issues

The following defects, drawn from DefectReport.xlsx, are severe enough on their own to block production release regardless of the overall pass rate:

DEF-004 / DEF-009 — Cross-account data isolation failure (Critical)

A newly created user's Dashboard displays another, unrelated user's Recent Chats and Knowledge Bases (TC-DB-005, TC-AU-004). This is a direct privacy breach: any user can potentially see another user's private data. This is the single most serious finding of the testing effort and must be root-caused (almost certainly a missing user-ID filter on the Dashboard/Knowledge Base queries) and fixed before any production traffic touches this build.

DEF-010 — No rate limiting on login (High)

Unlimited incorrect login attempts are allowed with no throttling, CAPTCHA, or lockout (TC-SE-003), leaving user accounts exposed to brute-force credential attacks.

DEF-003 — Unconfirmed handling of SQL-injection-style input at signup (High)

Signup accepted adversarial input (TC-SU-012) with no visible error, but safe parameterization could not be confirmed from the UI alone. Must be verified at the database layer before release.

3. Other Known Issues (Non-blocking)

The remaining 8 logged defects are Medium or Low severity — cosmetic, edge-case, or usability gaps that do not put user data or core workflows at risk. These do not need to block release but should be scheduled for a near-term patch:

- **Medium:** duplicate knowledge base URLs can be indexed without warning (DEF-005); mobile layout misalignment at ~375px width (DEF-011); logout button not consistently visible/accessible across all screens (TC-SM-005).
- **Low:** Full Name field has no length/format validation at signup, allowing 255+ character or emoji-only names (DEF-001, DEF-002); citation cards show 'N/A' for section metadata (DEF-006).

4. AI-Specific Observations

The 20 AI-related cases executed to date (prompt injection, jailbreak framing, hallucination checks, multilingual input, response consistency) passed with only 1 failure (citation section metadata — already listed as DEF-006). Core AI safety behaviors — declining to reveal system instructions, not fabricating answers outside the indexed content, and staying consistent across repeated questions — held up under adversarial testing. However, 30 additional AI test cases covering guardrails, deeper injection/jailbreak variants, and long-prompt handling (AITestingSuite, Part 9) are still pending execution and should be completed before final sign-off, since AI behavior can be inconsistent across prompt variations.

5. Recommendation and Reasoning

Verdict: Not Ready for Release.

An 87% functional pass rate would, on its own, typically support a 'Release with Known Issues' decision. However, release readiness is not just a pass-rate calculation — the nature of the failures matters as much as the count. DEF-004 and DEF-009 represent a cross-account data leak: a core trust and privacy guarantee (that a user's own data stays private to them) is broken. Shipping this to production tomorrow would expose real user data to other real users from day one, with likely reputational, and potentially legal, consequences. Combined with an unverified injection-handling concern (DEF-003) and no brute-force protection on login (DEF-010), the security posture of this build is not acceptable for production traffic.

None of the remaining Medium/Low defects, individually or together, would justify withholding release — they are the kind of issues a 'Release with Known Issues' decision exists for. It is specifically the Critical data-isolation defect that changes the verdict.

6. Conditions to Reach 'Ready for Release'

- Fix the Dashboard/Knowledge Base user-scoping bug (DEF-004/DEF-009) and re-run TC-DB-005 and TC-AU-004, plus a full regression pass on Authorization and Dashboard modules.
- Confirm (at the code/database level, not just the UI) that all user input is safely parameterized against injection (DEF-003).
- Implement login rate limiting or account lockout after repeated failures (DEF-010) and verify with the corresponding Postman brute-force request.
- Complete execution of the 30 pending AI-testing cases in AITestingSuite (Part 9), with particular attention to the Guardrails category.

Once the above are verified, this application would be a reasonable candidate for **'Release with Known Issues'**, with the remaining Medium/Low defects tracked for a follow-up patch.

Prepared by: QA Testing Intern | Based on Parts 3, 4, 9, and 10 of this assignment.